BTS CIEL ~ Activité mises à jour de sécurité

Nom : _____

Merci de faire un compte-rendu à rendre sur EcoleDirecte via « Cahier de textes->Rendre en ligne ».
Contexte : La société BERTIM doit décider si certaines mises à jour peuvent être déployées immédiatement sans compromettre ses développements en cours.

1 Mise à jour : Pourquoi ?

Les appareils numériques et les logiciels que nous utilisons au quotidien sont exposés à des failles de sécurité. Ces failles peuvent être utilisées par des cybercriminels pour prendre le contrôle d'un ordinateur, d'un équipement mobile ou encore d'une montre connectée. Face à ces risques, les éditeurs et les fabricants proposent des mises à jour (patch en anglais) visant à corriger ces failles. Si l'opération de mise à jour est souvent ressentie comme une contrainte, il s'agit pourtant d'un acte essentiel pour se protéger.

Source : cybermalveillance.gouv.fr/tous-nos-contenus/bonnes-pratiques/mises-a-jour

Quelques exemples de failles de sécurité
• ***Aux États-Unis,*** *des cybercriminels ont réussi à dérober des données confidentielles d'un* ***casino grâce au thermomètre connecté*** *présent dans un aquarium de l'établissement.*
• ***En France,*** *la* ***trottinette*** *électrique connaît un succès grandissant.* ***Une faille de sécurité sur certains modèles*** *a été découverte. Elle permettait d'exécuter certaines commandes sans avoir besoin du mot de passe comme* ***les déverrouiller, contrôler l'accélération ou le freinage.*** *Une mise à jour a été publiée pour corriger cette faille.*

2 Mise à jour manuelles vs automatiques

Mise à jour automatique généralement par défaut sur la plupart des OS
Pourquoi cela peut être intéressant de faire des mises à jour manuelles ?

- contrôle et flexibilité.
- choix du bon moment.
- examen des mises à jour test des applications
- Prends plus de temps et d'efforts, expose le système d'exploitation à des risques de sécurité et limite l'accès aux nouvelles fonctionnalités et logiciels.

3 Examen des mises à jour

Vous êtes responsable informatique de la société BERTIM, qui comporte un bureau d'étude en développement logiciel embarqué. Les développements portent sur des cartes électroniques équipant des systèmes embarqués dans du matériel militaire, médical et spatial. Les postes de travail fonctionnent avec un OS Linux, tout comme les systèmes embarqués développés.
Démarrez une machine et ouvrez le gestionnaire de mises à jour (icône  en bas à droite)

!!! Ne faites pas (encore) les mises à jour !!!

1. Combien de mises à jour sont en attente ? Combien de mises à jour de sécurité ?

2. Choisir une mise à jour de sécurité et relever les informations suivantes :

- Nom du paquet logiciel
- Décrire en quelques mots à quoi sert le logiciel choisi (visez des logiciels que vous connaissez, ou faites une recherche)
- Niveau d'urgence (Negligible, Low, Medium, High, Critical)
- Description de la mise à jour, ou du problème
- Nom d'un des fichiers source concerné (xxxx.c, yyy.h …)
- Numéro de CVE (Common Vulnerabilities and Exposures)
- Date
- Auteur

3. À l'aide du numéro de CVE, rendez vous sur le site ubuntu.com/security/cves pour visualiser les détails. Relever le score CVSS« Common Vulnerability Scoring System » et le vecteur d'attaque.

Exemples de vecteurs d'attaque :
Physical (P) : l'attaquant doit avoir un accès physique à la machine ou au dispositif.
Local (L) : l'attaquant doit déjà avoir un accès local à la machine, par exemple un compte utilisateur, pour exploiter la faille.
Network (N) : la vulnérabilité peut être exploitée à distance via le réseau

4. La société BERTIM utilise pour ses développements le compilateur « gcc ». (Un compilateur est un programme qui transforme le code source des développeurs d'application en un programme exécutable par le processeur). En quoi une mise à jour du programme gcc pourrait impacter son activité ? Que proposez-vous de faire ?

   Les vulnérabilités mentionnent régulièrement des correctifs sous forme de patches, ou de fichiers .diff. Ces fichiers .diff servent à modifier le code source de logiciels afin de corriger des failles. Voici un exemple de correction de vulnérabilité sur un extrait de code :
   Avant correction : code vulnérable

```
#include <stdio.h>
int main() {
char buffer[64];
printf("Entrez votre nom : ");
gets(buffer); // !!! Vulnérable : pas de contrôle de taille
printf("Bonjour %s!\n", buffer);
return 0;
}
```

   Après correction : code sécurisé

```
#include <stdio.h>
int main() {
char buffer[64];
printf("Entrez votre nom : ");
fgets(buffer, sizeof(buffer), stdin); // Sécurisé =D : limite la taille
printf("Bonjour %s!\n", buffer);
return 0;
}
```

5. Créer un « diff », en utilisant la procédure suivante :

- Dans votre répertoire de travail, créer un fichier code_vulnerable.c et un fichier code_secure.c qui contiennent respectivement les deux extraits ci-dessus.
- Faire clic droit → Ouvrir dans un terminal, puis entrer dans le terminal la commande suivante :

```
diff code_vulnerable.c code_secure.c
```

6. Indiquer le résultat obtenu. Par quels caractères ASCII les lignes de code supprimées et ajoutées sont mises en évidence ? S'aider de l'annexe « Fichiers .diff » en fin de document si besoin.

7. Aller à l'adresse https://sources.debian.org/src/gcc-13/13.3.0-12/debian/patches/asan-allocator-base.diff. Sans chercher à analyser le code, indiquer par quels caractères ASCII les lignes de code supprimées et ajoutées sont mises en évidence ?

8. Le terme « overflow » revient de façon récurrente dans les descriptions des mises à jour de sécurité. Expliquer avec en quoi cela consiste (faites une recherche si besoin, mais pas de copier/coller).

   Ouvrez un terminal (CTRL + ALT + T) et faites les mises à jour en mode terminal via les commandes :

```
sudo apt update #chercher les mises à jour
sudo apt upgrade –dry-run #afficher les mises à jour
sudo apt upgrade –dry-run | grep secu  #n'afficher que les lignes contenant « secu »
```

9. En observant le résultat, indiquez le nombre de mises à jour de sécurité

4 Préconisations

Préparez une synthèse pour sensibiliser votre équipe, ou vous présentez :

- La conduite à adopter pour les mises à jour.

- Un exemple d'attaque. (Il est bien sûr autorisé de faire des recherches.)

Annexe : Extrait des mises à jour de sécurité Linux Mint

```
abseil (0~20210324.2-2ubuntu0.2) jammy-security; urgency=medium
  * SECURITY UPDATE: Heap buffer overflow.
    - debian/patches/CVE-2025-0838.patch: Add MaxValidCapacity and use
      MaxValidCapacity for checks in ./absl/container/internal/raw_hash_set.h.
    - CVE-2025-0838
  * debian/patches/0001-skip-test-ppc64el-ftbfs.patch: Skip tests causing build
    failures on ppc64el architecture in
    ./absl/debugging/failure_signal_handler_test.cc.

 -- Hlib Korzhynskyy <hlib.korzhynskyy@canonical.com>  Wed, 07 May 2025 15:02:56 -0230
abseil (0~20210324.2-2) unstable; urgency=medium

  * Disable a test that doesn't play well with multiarch on armel and
    armhf.

 -- Benjamin Barenblat <bbaren@debian.org>  Mon, 07 Feb 2022 11:54:21 -0500


 aom (3.3.0-1ubuntu0.1) jammy-security; urgency=medium

  * SECURITY UPDATE: Integer overflow in img_alloc_helper
    - debian/patches/CVE-2024-5171.patch: avoid integer overflows in
      align_image_dimension() in aom/aom_image.h, aom/src/aom_image.c,
      test/aom_image_test.cc.
    - CVE-2024-5171

 -- Chrisa Oikonomou <chrisa.oikonomou@canonical.com>  Thu, 20 Mar 2025 15:02:11 +0200


gcc-11 (11.4.0-1ubuntu1~22.04.2) jammy-security; urgency=medium
* SECURITY UPDATE: A missed hardening option in -fstack-protector for AArch64
    can lead to buffer overflows for dynamically allocated local variables
    not being detected. (LP: #2054343)
    - d/p/CVE-2023-4039.diff: Address stack protector and stack clash
      protection weaknesses on AArch64. Taken from the gcc-12 branch.
    - CVE-2023-4039
  * Move allocator base to avoid conflict with high-entropy ASLR for x86-64
    Linux. Patch taken from LLVM. Fixes ftbfs. (LP: #2107313)
    - d/p/lp2107313-asan-allocator-base.diff


gcc-12 (12.3.0-1ubuntu1~22.04.2) jammy-security; urgency=medium

  * SECURITY UPDATE: A missed hardening option in -fstack-protector for AArch64
    can lead to buffer overflows for dynamically allocated local variables
    not being detected. (LP: #2054343)
    - d/p/CVE-2023-4039.diff: Address stack protector and stack clash
      protection weaknesses on AArch64. Taken from the gcc-12 branch.
    - CVE-2023-4039
  * Move allocator base to avoid conflict with high-entropy ASLR for x86-64
    Linux. Patch taken from LLVM. Fixes ftbfs. (LP: #2107313)
    - d/p/lp2107313-asan-allocator-base.diff
  * aarch64: Fix loose ldpstp check. (LP: #2116909)
    - d/p/lp2116909-aarch64-fix-loose-ldpstp-check.diff

 -- Gerald Yang <gerald.yang@canonical.com>  Tue, 15 Jul 2025 03:45:40 +0000



ghostscript (9.55.0~dfsg1-0ubuntu5.12) jammy-security; urgency=medium

  * SECURITY UPDATE: Information Leak
    - debian/patches/CVE-2025-48708.patch: Argument sanitization handle
      '#' as per '='
    - CVE-2025-48708

 -- Bruce Cable <bruce.cable@canonical.com>  Thu, 03 Jul 2025 15:29:51 +1000

ghostscript (9.55.0~dfsg1-0ubuntu5.11) jammy-security; urgency=medium

  * SECURITY UPDATE: Buffer overflow via serialization of DollarBlend
    - debian/patches/CVE-2025-27830.patch: fix potential Buffer overflow
```

```
      in base/write_t1.c, psi/zfapi.c.
    - CVE-2025-27830
  * SECURITY UPDATE: Text buffer overflow with long characters
    - debian/patches/CVE-2025-27831-pre1.patch: fix decode_glyph for
      Unicode in devices/vector/doc_common.c.
    - debian/patches/CVE-2025-27831.patch: prevent Unicode decoding overrun
      in devices/vector/doc_common.c.
    - CVE-2025-27831


git (1:2.34.1-1ubuntu1.15) jammy-security; urgency=medium

  * SECURITY REGRESSION: Breakage when using gitk and git gui. (LP: #2116251)
    - debian/patches/CVE-2025-27613.patch: Added back.
    - debian/patches/CVE-2025-27613-post1.patch: Change usage of
      safe_open_command_redirect to safe_open_command in some commands in
      gitk-git/gitk.
    - debian/patches/CVE-2025-46835-pre1.patch: Added back.
    - debian/patches/CVE-2025-46835.patch: Added back.
    - debian/patches/CVE-2025-46835-post1: Change git_read to safe_open_command
      in git-gui/git-gui.sh.

 -- Hlib Korzhynskyy <hlib.korzhynskyy@canonical.com>  Wed, 09 Jul 2025 17:16:10 -0230


gst-plugins-base1.0 (1.20.1-1ubuntu0.5) jammy-security; urgency=medium

  * SECURITY UPDATE: DoS via stack overflow in subparse plugin
    - debian/patches/CVE-2025-47806.patch: make sure that subrip time
      string is not too long before zero-padding in
      gst/subparse/gstsubparse.c.
    - CVE-2025-47806


gst-plugins-good1.0 (1.20.3-0ubuntu1.4) jammy-security; urgency=medium

  * SECURITY UPDATE: buffer over-read in isomp4 plugin
    - debian/patches/CVE-2025-47183.patch: use byte reader to parse mvhd
      box in gst/isomp4/qtdemux.c.
    - CVE-2025-47183



intel-microcode (3.20250512.0ubuntu0.22.04.1) jammy-security; urgency=medium

  * SECURITY UPDATE: New upstream microcode datafile 20250512
    - New microcodes:
      sig 0x000a06d1, pf_mask 0x20, 2025-02-07, rev 0xa0000d1, size 1635328
      sig 0x000a06d1, pf_mask 0x95, 2025-02-07, rev 0x10003a2, size 1664000
      sig 0x000b0650, pf_mask 0x80, 2025-03-18, rev 0x000a, size 136192
      sig 0x000b06d1, pf_mask 0x80, 2025-03-18, rev 0x011f, size 79872
      sig 0x000c0652, pf_mask 0x82, 2025-03-20, rev 0x0118, size 90112
      sig 0x000c0662, pf_mask 0x82, 2025-03-20, rev 0x0118, size 90112
      sig 0x000c0664, pf_mask 0x82, 2025-03-20, rev 0x0118, size 90112
      sig 0x000c06a2, pf_mask 0x82, 2025-03-20, rev 0x0118, size 90112
    - Updated microcodes:
      sig 0x00050657, pf_mask 0xbf, 2024-12-12, rev 0x5003901, size 39936
      sig 0x0005065b, pf_mask 0xbf, 2024-12-12, rev 0x7002b01, size 30720


iputils (3:20211215-1ubuntu0.1) jammy-security; urgency=medium

  * SECURITY UPDATE: DoS via crafted ICMP Echo Reply packet
    - debian/patches/CVE-2025-47268: fix signed 64-bit integer overflow in
      RTT calculation in iputils_common.h, ping/ping_common.c.
    - debian/patches/CVE-2025-48964.patch: fix moving average rtt
      calculation in iputils_common.h, ping/ping.h, ping/ping_common.c.
    - CVE-2025-47268
    - CVE-2025-48964

 -- Marc Deslauriers <marc.deslauriers@ubuntu.com>  Thu, 24 Jul 2025 07:51:44 -0400



openssh (1:8.9p1-3ubuntu0.13) jammy-security; urgency=medium

  * SECURITY UPDATE: incorrect DisableForwarding directive behaviour
    - debian/patches/CVE-2025-32728.patch: fix logic error in session.c.
    - CVE-2025-32728
```

```
  * SECURITY UPDATE: Signature verification bypass
    - debian/patches/CVE-2020-16156-1.patch: signature
      verification type CANNOT_VERIFY was not recognized



perl (5.34.0-3ubuntu1.5) jammy-security; urgency=medium

  * SECURITY UPDATE: threads race condition in file operations
    - debian/patches/fixes/CVE-2025-40909-metaconfig.diff: check for
      fdopendir in regen-configure/U/perl/d_fdopendir.U.
    - debian/patches/fixes/CVE-2025-40909-1.diff: clone dirhandles without
      fchdir in Configure, Cross/config.sh-arm-linux,
      Cross/config.sh-arm-linux-n770, Porting/Glossary, Porting/config.sh,
      config_h.SH, configure.com, plan9/config_sh.sample, sv.c,
      t/op/threads-dirh.t, win32/config.gc, win32/config.vc.
    - debian/patches/fixes/CVE-2025-40909-2.diff: minor corrections in
      Cross/config.sh-arm-linux, Cross/config.sh-arm-linux-n770,
      config_h.SH,plan9/config_sh.sample.
    - debian/patches/fixes/CVE-2025-40909-3.diff: use PerlLIO_dup_cloexec
      in Perl_dirp_dup to set O_CLOEXEC in sv.c.
    - debian/patches/fixes/CVE-2025-40909-metaconfig-reorder.diff: slightly
      reorder Configure and config_h.SH to match metaconfig output in
      Configure, config_h.SH.
    - debian/patches/fixes/CVE-2025-40909-generated.diff: update generated
      files and checksums in uconfig.sh, uconfig64.sh, uconfig.h,
      NetWare/config.wc.
    - CVE-2025-40909

 -- Marc Deslauriers <marc.deslauriers@ubuntu.com>  Fri, 25 Jul 2025 13:26:40 -0400

python3.10 (3.10.12-1~22.04.11) jammy-security; urgency=medium

  * SECURITY UPDATE: Regular expression denial of service.
    - debian/patches/CVE-2025-6069.patch: Improve regex parsing in
      Lib/html/parser.py.
    - CVE-2025-6069
  * SECURITY UPDATE: Infinite loop when parsing tar archives.
    - debian/patches/CVE-2025-8194.patch: Raise exception when count < 0 in
      Lib/tarfile.py.
    - CVE-2025-819

sudo (1.9.9-1ubuntu2.5) jammy-security; urgency=medium

  * SECURITY UPDATE: Local Privilege Escalation via host option
    - debian/patches/CVE-2025-32462.patch: only allow specifying a host
      when listing privileges.
    - CVE-2025-32462
```

Annexe : Fichiers .diff

--- a/foo.c → ancien foo.c

+++ b/foo.c → nouveau foo.c

- → ligne supprimée de l'ancienne version

+ → ligne ajoutée dans la nouvelle version

@@ -10,7 +10,8 @@ → indique les numéros de lignes autour de la modification :

Dans l'ancien fichier, le bloc commence à la ligne 10 et contient 7 lignes.

Dans le nouveau fichier, le bloc commence à la ligne 10 et contient 8 lignes.